

SEE ALSO Newsletter of March 28, 2024

[doc. web no. 9995680]

Provision of February 22, 2024

Register of Provisions

no. 105 of February 22, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting today, attended by

Prof. Pasquale Stanzone, president, Prof. Ginevra Cerrina Feroni, vice president, Dr. Agostino Ghiglia and Attorney Guido Scorza, members, and Secretary General Fabio Mattei;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016 (hereinafter, "Regulation");

HAVING REGARD TO the Code regarding the protection of personal data, containing provisions for the adaptation of national legislation to Regulation (EU) 2016/679 (Legislative Decree of June 30, 2003, no. 196, as amended by Legislative Decree of August 10, 2018, no. 101, hereinafter "Code");

HAVING REGARD TO the complaints submitted pursuant to Article 77 of the Regulation against L'Igiene Urbana Evolution s.r.l.;

HAVING EXAMINED the documentation on file;

HAVING REGARD TO the observations made by the Secretary General pursuant to Article 15 of the Guarantor's Regulation no. 1/2000;

REPORTING Attorney Guido Scorza;

PREAMBLE

1. The complaints against the Company.

On October 24, 2022, some employees of L'Igiene Urbana Evolution s.r.l. (hereinafter, the Company) filed a complaint with the Authority, alleging that, starting from February 2022, in order to access the construction site located in Ardea, where the employees' work activities take place, and to ascertain their presence at the workplace, it was necessary to use a biometric detector based on facial recognition. According to the documentation, including photographic evidence, attached to the complaints, the processing would have been carried out using the device "Face Deep 3 – Smart Face Recognition System," produced by Anviz Global. According to the complaints, the processing of biometric personal data would be "illegitimate," also considering that the purpose of the same "could equally be achieved by means less invasive of the personal sphere of the worker."

2. The investigative activity.

The Authority delegated the Special Privacy and Technological Fraud Unit of the Guardia di Finanza to carry out inspection checks pursuant to Articles 157 (Request for information and production of documents) and 158 (Checks) of the Code. On January 19, 2023, the Unit, together with personnel from the Authority, went to the construction site located in Ardea, where they recorded the following statements:

"within the industrial site, the following companies operate: L'Igiene Urbana Evolution s.r.l., Airone società consortile a r.l., Blue Work s.r.l., which operate as a temporary association of enterprises (ATI) for the management of waste in the Municipality of Ardea" (inspection report 19/1/2023, p. 2);

"within a room adjacent to the vehicle park, there is a device for recognizing employees based on facial biometrics [...]. The system is used for attendance tracking, by about 63 employees of the companies [operating at the site] plus any seasonal or temporary substitutes" (report cited, p. 3);

"the registration phase of the employees, carried out over a period of a few months, was done by entering the employee code (ID) associated with the name, based on a list provided by the company itself. Once this ID was entered, the employee's face was recognized [...] and the system validated the registration" (report cited, p. 3);

"in the room where the device is located, there are also always attendance sheets that are used as an alternative to facial recognition in case of malfunction of the device" (report cited, p. 3); during the verification activity, the inspectors found that "the device is operational and connected to the network [...]. By accessing with the Admin credentials, as reported in the user manual and not modified during installation, the data related to the time stamps and user records were exported, and a

backup of the internal database was performed” (report cited, p. 3); access was also made to the JuniorWeb application “through which the attendance of employees is managed, as recorded through the facial recognition device. Exports of the records were made, including those of dismissed employees, and it was verified that the system reports the indication of 3 additional companies (DMT, IGNEVO, UNICA srl) and 17 additional cost centers” (report cited, p. 3); “the companies managing the system are the three previously indicated, part of the ATI and [...] the system was installed by Igiene Urbana Evolution” (report cited, p. 4).

On January 26, 2023, during the inspection carried out at the administrative headquarters of L'igiene Urbana Evolution s.r.l., the Company stated that:

“the Temporary Association of Enterprises (ATI) was established in January 2020 [...]. Currently, the ATI consists of the companies: L'Igiene Urbana Evolution and Blu Work. [...] In March 2021, solely for the operational management of the contract, the companies L'Igiene Urbana Evolution and Blu Work established Airone società consortile a r.l.” (report

of personal data, which states that the biometric device complies with the applicable regulations (verbale cit., p. 4);

“the company has implemented measures to ensure the security of biometric data, including encryption and restricted access to the data” (verbale cit., p. 4);

“the biometric data collected is stored for a limited period, after which it is deleted in accordance with the data retention policy” (verbale cit., p. 4);

“the employees have been informed about the processing of their biometric data and have provided their consent as required by law” (verbale cit., p. 4);

“the company has appointed a Data Protection Officer (DPO) to oversee compliance with data protection regulations” (verbale cit., p. 4);

“the DPO is responsible for ensuring that all processing activities are documented and that employees are trained on data protection matters” (verbale cit., p. 4);

“the company conducts regular audits to assess compliance with data protection laws and to identify any potential risks” (verbale cit., p. 4);

“in case of any data breaches, the company has established a protocol for notifying the relevant authorities and affected individuals” (verbale cit., p. 4);

“the company is committed to protecting the privacy and rights of its employees and takes data protection seriously” (verbale cit., p. 4).

of the data by the device supplier (minutes cited, p. 4).

On May 30, 2023, in light of the statements made during previous inspections, inspections were also carried out at the registered office of DM Technology s.r.l.

The latter declared that:

“of the three accounts assigned [by the device supplier], one account, used by DM, had an Admin profile, with the ability to operate fully on the application and have visibility of the data of the 3 companies” (inspection minutes May 30, 2023, p. 3);

“once the use of the FD3 devices was fully operational, DM provided assistance on Junior Web for Unica, Igiene Urbana, and DM itself [...] through [the account provided by the supplier] it was possible to see the data of the time stamps of the cost centers belonging to Unica, Igiene Urbana Evolution, and DM” (minutes cited, p. 3).

3. The initiation of the procedure for the adoption of corrective measures and the Company's deductions.

On September 13, 2023, the Office notified the Company of the alleged violations of the Regulation found, with reference to Articles 5, paragraph 1, letter a), 9, paragraph 2, 13, 28, 30, 32, and 35 of the Regulation, pursuant to Article 166, paragraph 5, of the Code.

In defensive memoranda sent on October 13, 2023, the Company stated that:

a. the Company found “in 2021 a significant worsening of the absenteeism phenomenon, particularly accompanied by fraudulent time stamps that certified the presence of employees who, in reality, were not regularly performing their duties: this is a topic that has seen a considerable aggravation, due to

the social clause, as outlined in Article 6 of the National Collective Labor Agreement for Environmental Hygiene”;

b. “the matter has been the subject of heated labor disputes [...]. These appeals concerned the request for recognition of wage differences for alleged overtime worked [...] but which, in fact, the Writer did not believe had ever actually been performed. The proceedings also had negative outcomes precisely because the Writer was unable to verify with certainty the actual working hours performed by the appellants (as paper attendance sheets were used)”;

c. “The ordinary countermeasures adopted for this purpose proved to be completely ineffective. It is in this context that, in exercising the physiological prerogatives of organization and control over the regular performance of services for defensive purposes, it was deemed necessary to adopt measures that, while fully respecting the rights of workers, would allow for the eradication of a distorting phenomenon”;

d. “the adoption of a presence detection system through facial recognition was realized by turning to [the device supplier], which markets a system implemented by a leading company in the market (Anviz Global), whose application (Face Deep 3 – Smart Face Recognition System) was presented as a tool fully compliant with the obligations arising from the protection of workers' personal data”;

e. “It should also be clarified that, in the minutes of January 19, 2023, regarding the content of the backup of the internal database of the device acquired by the inspectors, the indication ‘time stamps and user records’ should, in fact, be understood as referring to a mere numerical code (corresponding to each worker) related to the date and time of the time stamp. [...] the encrypted biometric templates, acquired during the enrollment phase [...], were associated with the aforementioned numerical codes, without any storage in the device of the name and surname of the individuals involved”;

f. “the biometric data resides exclusively in the device and is not accessible remotely, nor locally, [...]”;

g. “the system is set up in such a way as to limit access to the encrypted data to only personnel with specific authorization credentials [...] It remains to be noted, certainly valid, regarding the lack of robustness of the password for access to the device application”;

h. “the staff has always been guaranteed the possibility of not using the application for facial recognition, replacing it with attendance sheets [...], as in the case, for example, of malfunction or non-activation of the devices”;

i. “immediately upon verification, the processing was suspended [...], a privacy consultant was appointed, and the procedure for the decommissioning of said biometric devices was identified, consisting of: disassembly, storage in protected locations, pending the conclusion of this procedure [...] and, at the end of the procedure, deletion of the data present on the devices; return to the supplying company; closure of the Junior Web account, software necessary to use the devices”;

j. “while considering the principle set forth in Article 24 of the GDPR and the related obligations in terms of accountability, it does not seem entirely neutral (as suggested in the contestation) that the company turned to a leading market supplier, which had provided full guarantees regarding the general compliance of the product, particularly emphasizing the element of data encryption and its irreversibility”;

k. “Finally, regarding the number of individuals involved, it should be noted that, concerning the site in Ardea, it involved approximately 37 employees.

(belonging to the three different companies that are part of the ATI) and that at each site they coincide with the only workers employed at the 9 involved sites, totaling 218 units (the figure cited in the notice, of 288 units, is the result of an incorrect count that also takes into account duplicate positions, as was attempted to be explained and documented during the inspection)”;

1. “in the period between 2021 and 2022, the Company incurred significant expenses due to the impact of the Covid-19 Pandemic specifically related to the substantial costs for personnel management and the sanitization of work environments; [...] the imposition of heavy monetary sanctions could have significant economic and financial impacts on business activities, with inevitable negative repercussions also on the already burdensome complex management of personnel in the difficult and complex work context in which the Writer operates.”

During the hearing requested by the Company, held on December 4, 2023, it finally asserted, among

other things, that:

- a. “with respect to the requests made by the workers in the complaints submitted to the Authority, following the inspection assessment, the Company immediately ordered the precautionary suspension of the processing carried out up to that point through the facial recognition system”;
- b. “the facial recognition system had been used because, albeit erroneously, the legal basis had been interpreted”;
- c. “although the Company did not comply with all the obligations imposed by data protection legislation, it took into account the security of the data, adopting the maximum security measures provided”;
- d. “Urban Hygiene and DM Technology did not proceed with the deletion of the data pending the conclusion of the procedure and in view of further checks by the Authority. However, a procedure for the deletion of the data collected with the facial recognition system has already been planned, which will be activated as soon as the procedure before the Authority is concluded.”

4.1. Violation of Article 5, paragraph 1, letter a) and 9 of the Regulation in relation to the processing of data of its employees.

As a result of the examination of the statements made to the Authority during the proceedings as well as the documentation acquired, it appears that the Company, as the data controller, has carried out some processing operations, related to the complainants, that are not compliant with the regulations on personal data protection. In this regard, it is highlighted that, unless the fact constitutes a more serious offense, anyone who, in a proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code “Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or the exercise of the powers of the Guarantor.”

On the merits, following the investigative activity, it was established that the Company used a biometric system, based on facial recognition, starting from December 2021 (the date on which the system was activated, according to what was stated by the Company; however, it did not clarify on what date the activities of recording employees with consequent data processing began) and until January 2023, the date on which the system was deactivated “as a precaution” following the initiation of the verification activity by the Authority.

The use of the biometric system, aimed at detecting the presence of employees at work, was determined, based on what was stated, by the multiplication of phenomena of “absenteeism” and disputes initiated against the Company itself by the workers regarding “claims for overtime pay.” Furthermore, the adoption of the biometric system, according to what the Company stated, was deemed necessary also due to the fact that “all employees at the Ardea site were [...] hired [...] under a social clause,” resulting in the employer's inability to choose the contractors of the employment contract.

The processing involved a significant number of data subjects, considering that, during the investigations, it emerged that the Company used the same type of biometric detector, not only at the Ardea site but also at an additional 9 sites where it carries out its activities (see minutes 27/1/2023, p. 2).

In particular, based on the examination of the “schedule regarding the various installation sites of the devices” provided by the Company, including the number of its employees employed at each site, it appears that the processing involved a total of 288 workers (see cited minutes, Annex 3).

Even subtracting the 12 workers from the site in the Municipality of Ravello, whose device was “installed [but] never went into operation,” as indicated in the schedule (without specifying whether data collection was carried out or not, which is still a processing operation), there would be a total of 276 employees, which is still a significant number of data subjects involved in the processing of biometric data.

Contrary to what was asserted in the defense briefs, moreover, the Company during the proceedings did not indicate or document the existence of “duplicate positions,” considering which the total number of subjects affected by biometric detection would instead amount to 218 employees, and in any case, even this number appears significant.

Preliminarily, it is noted that, as clarified by the Authority, there is processing of biometric data.

both in the registration phase (so-called enrolment), consisting of the acquisition of the biometric characteristics of the interested party (facial characteristics, in this specific case; see points 6.1 and 6.2 of Annex A to the provision of the Guarantor of November 12, 2014, no. 513, at www.garanteprivacy.it, web doc. no. 3556992), and in the biometric recognition phase, at the time of attendance detection (see also point 6.3 of Annex A to the aforementioned provision). Therefore, even in the case of the extraction of the so-called template, there is processing of biometric data, with the consequent application of the specific regulations provided for by the legal system.

In this regard, based on the regulations concerning the protection of personal data, the processing of biometric data (generally prohibited under Article 9, paragraph 1 of the Regulation) is allowed only if one of the conditions indicated in Article 9, paragraph 2 of the Regulation is met and, with regard to processing carried out in the employment context, only when the processing is “necessary to fulfill the obligations and exercise the specific rights of the data controller or the data subject in the field of labor law and social security and social protection, to the extent that it is authorized by Union law or the laws of the Member States or by a collective agreement under the laws of the Member States, in the presence of appropriate safeguards for the fundamental rights and interests of the data subject” (Article 9, paragraph 2, letter b), of the Regulation; see also: Article 88, paragraph 1 and recitals 51-53 of the Regulation).

The employer is also required to apply the general principles of processing, in particular those of lawfulness, fairness, and transparency, minimization, integrity, and confidentiality of data (Article 5, paragraph 1, letters a), c) and f) of the Regulation). In application of these provisions, although in the employment context the purposes of detecting employee attendance and verifying compliance with working hours may fall within the scope of Article 9, paragraph 2, letter b) of the Regulation, the processing of biometric data is allowed only “to the extent that it is authorized by Union law or the laws of the Member States [...] in the presence of appropriate safeguards for the fundamental rights and interests of the data subject” (Article 9, paragraph 2, letter b), and recitals 51-53 of the Regulation).

Taking into account also what is provided for by Article 2-septies of the Code (Guarantee measures for the processing of genetic, biometric, and health-related data), under which the aforementioned processing may be carried out in accordance with the guarantee measures established by the Guarantor (pursuant to Article 9, paragraph 4, of the Regulation), the current legal framework does not allow for the processing of biometric data of employees for the purpose of attendance detection. This has been reiterated by the Guarantor in provisions no. 369, of November 10, 2022 (web doc. no. 9832838) and no. 16, of January 14, 2021 (web doc. no. 9542071).

The use of biometric data in the context of the ordinary management of the employment relationship (such as attendance detection) for the stated purpose of addressing disciplinary violations, disputes related to the payment for overtime work, as well as due to the presence of personnel at the site where the verification activity was carried out through the application of the so-called social clause (although this last reason is not relevant, also considering that the reasons for which the biometric system was adopted at other 9 sites managed by the Company have not been disclosed), is therefore not compliant with the principles of minimization and proportionality of processing (Article 5, paragraph 1, letter c) of the Regulation).

It is noted, in this regard, that the Company did not illustrate (nor document during the proceedings) what “ordinary countermeasures” had been concretely adopted and had proven to be “completely ineffective,” in order to account for the actual hours of work performed and to ascertain the presence of workers at the workplace; useful measures could have been adopted for this purpose that are less invasive of the rights of the interested parties (e.g., automatic checks via badges, direct verifications, etc.).

The proportionality assessment of the processing of biometric data consisting of facial recognition should also take into account the risks to the rights and freedoms of the interested parties associated with the use of this particular biometric technology, as recognized both by national legislation and in the European context (see Legislative Decree 10/5/2023, no. 51, converted into Law 3/7/2023, no. 87,

which with Article 8-ter extended until December 31, 2025, the suspension of the installation and use of video surveillance systems with facial recognition "in public places or open to the public, by public authorities or private entities," in order to "regulate in accordance with the admissibility requirements, conditions, and guarantees related to the use of facial recognition systems in compliance with the principle of proportionality provided for by Article 52 of the Charter of Fundamental Rights of the European Union"; see also: European Data Protection Board, Guidelines 05/2022 on the use of facial recognition technology in the area of law enforcement, adopted on 26/7/2023, especially points 17, 34, and 35 on the risks of facial recognition; Guidelines 3/2019 on the processing of personal data through video devices, adopted on January 29, 2020, especially points 4 and 73; see also the Provision of February 10, 2022, no. 50, web doc. no. 9751362, adopted, although in a different context, concerning...

****4.1. Violation of Articles 5, Paragraph 1, Letter a) and 9 of the Regulation.****

Finally, the fact that the manufacturer and supplier of the facial recognition devices (subjects who must, in any case, take into account the right to data protection: see Recital 78 of the Regulation) had produced a "declaration and certification of conformity of the biometric device [...], in which it was stated that the device was fully compliant with the GDPR" (see inspection report 26/1/2023, p. 4), does not absolve the Company of responsibility, considering that the data controller, in light of what is established by Article 5, Paragraph 2, of the Regulation, based on the so-called accountability principle, "is responsible for compliance [with the general principles of processing] and is able to demonstrate it," with regard to the obligations that weigh on it (Article 24 of the Regulation).

This is also taking into account that, in the specific case, the Authority, even recently (as mentioned above), has ruled on the legitimacy criteria and the principles applicable to the processing of biometric data within the employment relationship, publishing on its institutional website the decisions adopted in this matter.

Therefore, the data controller, before proceeding with the use of devices made by third parties, should have verified the compliance of the related processing with the applicable principles.

Lastly, it is noted that the possibility of using signature sheets was not an alternative, as deduced by the Company, to the use of the facial recognition device, since employees could only resort to it, based on what emerges from the documentation present in the records, in case of malfunctioning of the biometric devices.

However, even if a non-biometric detection system had been made available to workers as an alternative to the biometric one, the data processing carried out would not have been compliant with the provisions on the protection of personal data as outlined above, and in practice would have been unnecessary with respect to the stated purpose of addressing the problems related to the use of signature sheets to attest to presence at the workplace.

Based on the aforementioned reasons, the processing of biometric data of its employees carried out by the Company is therefore found to have been conducted in the absence of an adequate legal basis, in violation of Articles 5, Paragraph 1, Letter a) and 9 of the Regulation.

****4.2. Violation of Articles 5, Paragraph 1, Letter a) and 9 of the Regulation in relation to the processing of data of employees of other companies.****

As a result of access to the system and examination of the documentation acquired in the records, it also emerged that the list of employees to be subjected to presence verification through the biometric detection system was, until its suspension, unique for the three companies operating at the Ardea construction site (in addition to the Company, also Airone società consortile a r.l. and Blue Work s.r.l.), which provided the list of their respective employees to be verified.

In fact, both the paper signature sheet and the attendance log extracted from the JuniorWeb application, as well as the data exported from the Anviz device, acquired in the records, present a shared list among the three companies where next to each name is indicated the company of belonging (see inspection report 19/1/2023, Annex 1 [Attendance Log January 2023 - report generated

by Junior Web and signature sheets of 19/1/2023], 2 [tables with data export extracted from the device] and 3 [screenshot access to data contained in the device]).

From the documentation acquired during the inspection, it also emerged that the processing overall carried out by the system also concerned the employees of Unica s.r.l.s. and DM Technology s.r.l. (see inspection report 27/1/2023, Annex 6, "Total employee export table," containing the list of clock-ins made as of 27/1/2023 related to the employees of L'Igiene Urbana Evolution s.r.l., Airone società consortile a r.l., Blue Work s.r.l., Unica s.r.l.s. and DM Technology).

Therefore, the Company also processed data related to the presence of employees of Airone società consortile a r.l., Blue Work s.r.l., Unica s.r.l.s. and DM Technology s.r.l., taken from the biometric presence detection system, equally in the absence of any of the applicable conditions, among those provided for by Article 9, Paragraph 2 of the Regulation.

The described processing therefore occurred in violation of Articles 5, Paragraph 1, Letter a) and 9 of the Regulation.

****4.3. Violation of Articles 5, Paragraph 1, Letter a) and 13 of the Regulation.****

The Authority has repeatedly emphasized that the employer, in application of the principle of transparency, has the obligation to inform its employees and collaborators, in any case, about the essential characteristics of the data processing carried out in the context of the employment relationship as well as the tools through which the processing is carried out, in accordance with what is specifically indicated by Article 13 of the Regulation.

This also considering that, within the employment relationship, the obligation to inform the employee is also an expression of the duty of fairness (Article 5, Paragraph 1, Letter a) of the Regulation).

In this case, however, it emerged that the Company failed to provide any information regarding the characteristics of the processing of biometric data through facial recognition (see report 26/1/2023, p. 5, where the Company stated that it had not provided "any specific information on the processing of biometric data").

This resulted in a violation of Articles 5, Paragraph 1, Letter a) and 13 of the Regulation.

4.4. Violation of Article 28 of the Regulation.

According to the provisions of the Regulation, the data controller, in the context of preparing the technical and organizational measures that are incumbent upon it, also with regard to security (Articles 24 and 32 of the Regulation), may use a processor to carry out certain processing activities, to which it gives specific instructions (see Recital 81 of the Regulation).

In this case, the controller "only uses processors that provide sufficient guarantees to implement [the aforementioned measures] in such a way that the processing meets the requirements of the Regulation and ensures the protection of the rights of the data subjects" (Article 28, paragraph 1, of the Regulation).

Pursuant to the aforementioned Article 28 of the Regulation, the controller may entrust processing to external parties, adequately regulating the relationship with a contract (or another legal act) and providing instructions regarding the main characteristics of the processing.

The processor is therefore authorized to process the data of the data subjects "only on the documented instructions of the controller" (Article 28, paragraph 3, letter a), of the Regulation) and within the specific limits defined by the data controller.

The Company, while utilizing the services provided by DM Technology s.r.l. regarding the management of the Junior Web application, carried out in ways that allowed it access to employee data related to attendance tracking and the related processing (see inspection report dated 30/5/2023 at DM Technology s.r.l., p. 3; see Maintenance Agreement dated 28/10/2020, signed by DM Technology and L'Igiene Urbana, Annex 2, inspection report dated 27/1/2023), did not designate the aforementioned company as the data processor, as required by Article 28 of the Regulation (see report dated 26/1/2023, p. 5).

Furthermore, it has emerged that the Company has availed itself of the services of "consulting,

assistance, and compliance in labor law" provided by Unica s.r.l.s. based on an agreement made between the parties (see "Consulting Agreement in Labor Matters/Professional Assistance," dated 28/12/2020), which expressly includes activities such as the preparation of sickness, maternity, vacation settlement statements, and the preparation of tables for union deductions, which necessarily involve the processing of personal data of the employees of the controller.

Also in relation to this activity, the Company did not designate the service provider as the data processor, as instead required by Article 28 of the Regulation.

It is noted that the Company, during the proceedings, produced a copy of the designation of DM Technology s.r.l. and Unica s.r.l.s. as data processors for the personal data processing carried out in execution of the agreement made between the parties, adopted on 1/6/2023 (see defense memoranda dated 13/10/2023, Annexes 5 and 6).

For the above reasons, as stated, the Company has therefore violated Article 28 of the Regulation.

4.5. Violation of Article 35 of the Regulation.

According to Article 35 of the Regulation, in relation to processing that involves "the use of new technologies, considering the nature, purpose, context, and objectives of the processing, [such as] to present a high risk to the rights and freedoms of natural persons," the controller is required to carry out a data protection impact assessment before the commencement of the intended processing.

In this regard, the Guidelines WP 248rev.01 of 4.4.2017 ("Guidelines on Data Protection Impact Assessment and Determining the Likelihood that Processing 'May Present a High Risk' for the Purposes of Regulation (EU) 2016/679") identify, among the criteria under which the data controller is required to carry out an impact assessment, relevant in this case, the processing of "sensitive data," which includes biometric data (see Chapter III, B, no. 4), processing carried out concerning "vulnerable" data subjects (e.g., as part of an employment relationship; see Chapter III, B, no. 7), as well as processing that involves "innovative use or [the] application of new technological or organizational solutions" (see Chapter III, B, no. 8).

Further indications have been provided in this regard by the decision of the Authority dated October 11, 2018, no. 467 ("List of Types of Processing Subject to the Requirement of a Data Protection Impact Assessment Pursuant to Article 35, Paragraph 4, of Regulation (EU) No. 2016/679," in G.U., S. G. no. 269 of 19.11.2018, specifically nos. 6 and 7), although referring to cross-border processing. Although having adopted a biometric authentication system for the purpose of tracking the attendance of its employees at all sites where they operate, the Company did not carry out an impact assessment before the commencement of the processing itself, thereby violating, as stated above, Article 35, paragraph 1 of the Regulation.

4.6. Violation of Articles 30 and 32 of the Regulation.

According to the provisions of Article 30 of the Regulation, within the register of processing activities carried out by the controller, the latter, under its own responsibility, is required to indicate the categories of personal data subject to processing (Article 30, paragraph 1, letter c) of the Regulation). As clarified by the Authority, the register constitutes one of the main elements of accountability of the controller, as a tool suitable for providing a

****Updated Framework of Ongoing Treatments****

within its own organization, essential for any risk assessment or analysis activity and therefore preliminary to such activities.

The register must be in written form, including electronic form, and must be presented upon request to the Authority (see the FAQs on the treatment activities register, made available by the Authority on its institutional website in October 2018, web doc no. 9047529).

In the specific case, it emerged that the treatment operations register dated 29/12/2021

does not indicate biometric data among the types of data processed by the data controller (see minutes 26/1/2023, Annex 5). This constitutes a violation of what is established by Article 30 of the Regulation.

Furthermore, during the access conducted during the inspection activity to the Anviz terminal, used for clocking in via facial recognition, it emerged that the authentication credentials with Admin profile were the same as those reported in the user manual (userID, so-called default ID, "0", password "12345") and had never been modified over time, thus from the date of installation in December 2021.

According to the Company's statements, other devices, in addition to the one installed at the Ardea site, had maintained the same standard credentials provided for the first access (see inspection reports 19/1/2023, p. 3 and 27/1/2023, p. 3).

This made it possible to access the information stored on the terminal based on the simple consultation of the device's user manual, easily available on the Internet, and in any case based on the typing of the first five cardinal numbers in ascending order (see Annex 2, inspection report 19/1/2023, containing photographic documentation of the accesses made, spec.

IMG_20230119_103040943.jpg).

Such conduct is not compliant with what is provided by Article 32 of the Regulation, according to which the data controller is required to implement "appropriate technical and organizational measures to ensure a level of security appropriate to the risk," ensuring "on a permanent basis the confidentiality" of the personal data processed, in light of "the state of the art and the costs of implementation, as well as the nature, the subject matter, the context, and the purposes of the processing, as well as the risk of varying probability and severity for the rights and freedoms of natural persons."

The Company has therefore also violated Article 32 of the Regulation.

5. ****Conclusions: Declaration of Illegality of the Processing. Corrective Measures pursuant to Article 58, par. 2, Regulation.****

For the reasons stated above, the Authority believes that the statements, documentation, and reconstructions provided by the data controller during the investigation do not allow for overcoming the observations notified by the Office with the initiation of the procedure and are therefore unsuitable to allow the archiving of the present procedure, nor does any of the cases provided for by Article 11 of the Regulation of the Authority no. 1/2019 apply. The processing of personal data carried out by the

Company, specifically the processing of biometric data (facial recognition) relating to its employees and those of other companies, for the purpose of attendance detection, is indeed illegal, as outlined above, in relation to Articles 5, par. 1, lett. a), 9, 13, 28, 30, 32, and 35 of the Regulation.

The violation, established in the terms outlined in the reasoning, cannot be considered “minor,” given the nature of the violation that has concerned the general principles and the conditions of legality of the processing of special data as well as the severity of the violation itself, the degree of responsibility, and the manner in which the supervisory authority became aware of the violation (see Recital 148 of the Regulation).

The Authority acknowledges, however, that, according to what has been declared under its own responsibility, the Company has suspended the processing of biometric data after the initiation of the inspection activity and has identified a “procedure for the disposal of biometric devices” which provides, among other things, that at the end of the procedure initiated by the Authority, the data stored on the devices will be deleted (see defensive memories 13/10/2023).

Therefore, in light of the corrective powers granted by Article 58, par. 2 of the Regulation, the procedure concludes with the sole application of an administrative monetary sanction, pursuant to Article 83 of the Regulation, commensurate with the circumstances of the specific case (Article 58, par. 2, lett. i) Regulation).

6. ****Adoption of the injunction order for the application of the administrative monetary sanction and ancillary sanctions (Articles 58, par. 2, lett. i), and 83 of the Regulation; Article 166, paragraph 7, of the Code).****

At the conclusion of the procedure, it appears that L'Igiene Urbana Evolution s.r.l. has violated Articles 5, par. 1, lett. a), 9, 13, 28, 30, 32, and 35 of the Regulation.

For the violation of the aforementioned provisions, the application of the administrative monetary sanction provided for by Article 83, par. 4, lett. a) and par. 5, lett. a) and b) of the Regulation is foreseen, through the adoption of an injunction order (Article 18, Law 24.11.1981, no. 689).

It is deemed necessary to apply paragraph 3 of Article 83 of the Regulation where it provides that “If, in

relation to the same processing or related processing, a data controller [...] violates, with

****Dolo o colpa, varie disposizioni del presente regolamento, l'importo totale della sanzione amministrativa pecuniaria non supera l'importo specificato per la violazione più grave**, l'importo totale della sanzione è calcolato in modo da non superare il massimo edittale previsto dal medesimo art. 83, par. 5.**

Con riferimento agli elementi elencati dall'art. 83, par. 2 del Regolamento ai fini della applicazione

della sanzione amministrativa pecuniaria e la relativa quantificazione, tenuto conto che la sanzione deve "in ogni singolo caso [essere] effettiva, proporzionata e dissuasiva" (art. 83, par. 1 del Regolamento), si rappresenta che, nel caso di specie, sono state considerate le seguenti circostanze: a) in relazione alla natura, gravità e durata della violazione, è stata considerata, a sfavore della Società, la natura della violazione che ha riguardato i principi generali e le condizioni di liceità del trattamento e il trattamento di dati particolari biometrici utilizzando la tecnologia del riconoscimento facciale;

b) è stata altresì considerata, a sfavore della Società, la durata della violazione che si è protratta per più di un anno e il numero significativo degli interessati coinvolti;

c) con riferimento al carattere doloso o colposo della violazione e al grado di responsabilità del titolare, è stata presa in considerazione la condotta della Società e il grado di responsabilità della stessa che non si è conformata alla disciplina in materia di protezione dei dati relativamente a una pluralità di disposizioni;

d) a favore della Società, si è tenuto conto della cooperazione con l'Autorità di controllo e della decisione di sospendere le attività di trattamento dopo l'inizio delle attività ispettive.

Si ritiene inoltre che assumano rilevanza nel caso di specie, tenuto conto dei richiamati principi di effettività, proporzionalità e dissuasività ai quali l'Autorità deve attenersi nella determinazione dell'ammontare della sanzione (art. 83, par. 1, del Regolamento), in primo luogo le condizioni economiche del contravventore, determinate in base ai ricavi conseguiti dalla Società con riferimento al bilancio ordinario d'esercizio per l'anno 2022. Da ultimo si tiene conto dell'entità delle sanzioni irrogate in casi analoghi.

Alla luce degli elementi sopra indicati e delle valutazioni effettuate, si ritiene, nel caso di specie, di applicare nei confronti di L'Igiene Urbana Evolution s.r.l. la sanzione amministrativa del pagamento di una somma pari ad euro 70.000 (settantamila).

In tale quadro si ritiene, altresì, in considerazione della tipologia delle violazioni accertate che hanno riguardato i principi generali e le condizioni di liceità del trattamento, che ai sensi dell'art. 166, comma 7, del Codice e dell'art. 16, comma 1, del Regolamento del Garante n. 1/2019, si debba procedere alla pubblicazione del presente provvedimento sul sito Internet del Garante.

Si ritiene, altresì, che ricorrano i presupposti di cui all'art. 17 del Regolamento n. 1/2019.

****TUTTO CIÒ PREMESSO, IL GARANTE****

rileva l'illiceità del trattamento effettuato da L'Igiene Urbana Evolution s.r.l., in persona del legale rappresentante, con sede legale in Via Roberto Lepetit, 8/10 Milano (MI), C.F. 11277540966, ai sensi dell'art. 143 del Codice, per la violazione degli artt. 5, par. 1, lett. a), 9, 13, 28, 30 e 32 del Regolamento;

****ORDINA****

ai sensi dell'art. 58, par. 2, lett. i) del Regolamento a L'Igiene Urbana Evolution s.r.l., di pagare la somma di euro 70.000 (settantamila) a titolo di sanzione amministrativa pecuniaria per le violazioni indicate nel presente provvedimento;

****INGIUNGE****

quindi alla medesima Società di pagare la predetta somma di euro 70.000 (settantamila), secondo le modalità indicate in allegato, entro 30 giorni dalla notifica del presente provvedimento, pena l'adozione dei conseguenti atti esecutivi a norma dell'art. 27 della legge n. 689/1981. Si ricorda che resta salva la facoltà per il trasgressore di definire la controversia mediante il pagamento – sempre secondo le modalità indicate in allegato - di un importo pari alla metà della sanzione irrogata, entro il termine di cui all'art. 10, comma 3, del d. lgs. n. 150 dell'1.9.2011 previsto per la proposizione del ricorso come sotto indicato (art. 166, comma 8, del Codice);

****DISPONE****

la pubblicazione del presente provvedimento sul sito web del Garante ai sensi dell'art. 166, comma 7, del Codice e dell'art. 16, comma 1, del Regolamento del Garante n. 1/2019, e ritiene che ricorrano i

presupposti di cui all'art. 17 del Regolamento n. 1/2019.

Richiede a L'Igiene Urbana Evolution s.r.l. di comunicare quali iniziative siano state intraprese al fine di cancellare i dati biometrici oggetto di conservazione sui dispositivi, e di fornire comunque riscontro adeguatamente documentato ai sensi dell'art. 157 del Codice, entro il termine di 90 giorni dalla data di notifica del presente provvedimento; l'eventuale mancato riscontro può comportare l'applicazione della sanzione amministrativa prevista dall'art. 83, par. 5, lett. e) del Regolamento.

Ai sensi dell'art. 78 del Regolamento, nonché degli articoli 152 del Codice e 10 del d.lgs. n. 150/2011, avverso il presente provvedimento può essere proposta opposizione all'autorità giudiziaria ordinaria, con ricorso depositato al tribunale ordinario del luogo individuato nel medesimo art. 10, entro il termine di trenta giorni dalla data di comunicazione del provvedimento stesso, ovvero di sessanta giorni se il ricorrente risiede all'estero.

Roma, 22 febbraio 2024

****IL PRESIDENTE****

Stanzione

****IL RELATORE****

Scorza

****IL SEGRETARIO GENERALE****

Mattei